

Race Condition Vulnerability Lab (TOCTOU)

Race 问题是并发程序常见的问题。最常见的，当多个线程访问同一个资源时，由于线程调度的不确定性，可能导致数据不一致的问题。一个本质的原因就是操作的 **非原子性**，**Time Of Check** 和 **Time Of Use** 之间的间隔，使得程序出现 **时序错误**。

Task 1: Choosing Our Target

在 `/etc/passwd` 中记录了当前机器的所有用户的用户名，**UID** 等信息，如果我们能够在其中写入一个新的用户，并将其 **UID** 设置为 `0`，那么我们就可以获得 **root** 权限。

用户的具体密码写在 `/etc/shadow` 中，但是如果我们在 `passwd` 中设定为 `U6aMy0wojraho`，就可以特别地设定为空密码。我们在 `task1` 中直接使用 `sudo` 写入 `test:U6aMy0wojraho:0:0:test:/root:/bin/bash`。效果如下：

```
[11/11/24]seed@VM:/etc$ su test
Password:
root@VM:/etc# exit
exit
[11/11/24]seed@VM:/etc$
```

Task 2: Launching the Race Condition Attack

在 `task2` 中，有漏洞的程序实现向 `/tmp/xyz` 中写入用户输入的内容。程序首先检查是否有写入的权限，此后再写入文件，这期间就有一个 **TOCTOU** 的漏洞。如果我们在程序检查到有写入权限后，写入前，另一个线程将文件软链接到 `/etc/passwd`，即可绕过检查进行写入。

Task 2.A: Simulating a Slow Machine

为了降低难度，我们在检查和写入之间 `sleep(10)`，然后开启另一个线程手动进行软链接的更改，很容易就成功了，如下：

```
[11/11/24]seed@VM:~/.../Labsetup$ ./vulp
test:U6aMy0wojraho:0:0:test:/root:/bin/bash
[11/11/24]seed@VM:~/.../Labsetup$

[11/11/24]seed@VM:~/.../Labsetup$ ln -sf /dev/null /tmp/XYZ
[11/11/24]seed@VM:~/.../Labsetup$ ln -sf /etc/passwd /tmp/XYZ
[11/11/24]seed@VM:~/.../Labsetup$ su test
Password:
root@VM:/home/seed/Desktop/Lab5-TOCTOU/Labsetup# exit
exit
[11/11/24]seed@VM:~/.../Labsetup$
```

Task 2.B: The Real Attack

在现实生活中受害者肯定不会给予攻击者如此的方便，我们需要让攻击自动化。实验为我们提供了重复执行漏洞程序的脚本，它会不断执行漏洞程序，直到发现 `\etc\passwd` 被改变，只要它的最后修改时间和原文件不同则说明攻击成功。我们在另一个 `shell` 中反复地断开软链接并重新建立软链接，以期攻击成功，大约尝试十几次之后攻击成功，如下：

Task 3.B: Using Ubuntu's Built-in Scheme

在实验开始前我们关闭了 Ubuntu 自带的保护措施，它要求在全局可写的 `sticky` 的文件夹中的文件，如果程序和文件夹的所有者与软链接指向的文件的所有者不匹配，则不会追踪软链接。这就保证了不能 **通过软链接来进行“越权”的文件操作**。